Cybersecurity:
Zero-Day Vulnerabilities and Attack Vectors

Dissertation Manuscript

Submitted to Northcentral University

School of Business

in Partial Fulfillment of the

Requirements for the Degree of

DOCTOR OF PHILOSOPHY

by

THOMAS LLOYD WILLIAMS

PREVIEW

La Jolla, California

May 2020

DocuSign Envelope ID: FFAF5BAE-1400-4E01-BD01-1E548DA3E0DA

Approval Page

Cybersecurity: Zero-Day Vulnerabilities and Attack Vectors

By

THOMAS LLOYD WILLIAMS

Approved by the Doctoral Committee:

DocuSigned by: David L. Lowery 352BD4337F3241A...	DPA, MS, MPA	03/17/2021 | 13:31:13 MST
Dissertation Chair: David L. Lowery	Degree Held	Date
DocuSigned by: Philip Verrecchia 4B42F1B1458844C...	Ph.D.	03/18/2021 | 09:52:05 MST
Committee Member: Philip Verrecchia	Degree Held	Date
DocuSigned by: Leila Sopko 1F89B29081C9435...	Ph.D., MBA	03/18/2021 | 11:44:44 MST
Committee Member: Leila Sopko	Degree Held	Date

PREVIEW

Abstract

The problem to be addressed by this study is a type of cybersecurity issue known as a zero-day vulnerability. A zero-day vulnerability is a moderately new form of cyber warfare and is an attack or threat that exploits a previously unknown vulnerability in a computer application. The purpose of this qualitative research project is to evaluate past cyber threats, synthesize and evaluate the threats, then produce a best practices strategy for the Information Technology Department Supervisor employed by a higher learning education facility. The goal of the research question is to identify the security parameters (if any) used for different cyber transactions and each cyber breach. Compiling this data focuses on proactivity of the effected entity, and identifies trends in the failure of securing cyber space. This research design uses a constant comparison analysis and focuses on the relationship between zero-day vulnerability attacks and the twenty critical controls of cyber defense. The study implies that there is a relationship between cyber defense and a zero-day vulnerability attack. Relationships exist between: (a) attack vector and zero-day vulnerability attacks, (b) attacked platform and zero-day vulnerability attacks, and (c) priority of critical control measures and zero-day vulnerability attacks. Phishing is by far the most prolific attack vector used against the Northcentral University cyber platform. After synthesizing the NCU data, the researchers surmise that ethics training needs to be a deliberate program to recalibrate the collective. Trusting third party software managers, and incentivizing healthy cyber security by end users are two avenues for future exploration.

PREVIEW

Acknowledgements

I would like to sincerely thank my dissertation committee, Dr. Lowery, Dr. Verrecchia, and Dr. Sopko for guiding me along this educational journey. I would like to thank all my professors, and Mr. Bridgman for giving me the knowledge to complete my task. I would also like to thank my wife Lisa, son Tommy, and daughter Ashley for encouraging me to complete my ambition.

PREVIEW

Table of Contents

Chapter 1: Introduction 1

Statement of the Problem 19
Purpose of the Study 20
Theoretical Framework 21
Nature of the Study 23
Research Questions 24
Hypotheses 24
Significance of the Study 25
Definitions of Key Terms 25
Summary 32

Chapter 2: Literature Review 35

Theoretical Framework 42
Cyber Issues 46
Cyber Risks 54
Cyber Solutions 65
Summary 75

Chapter 3: Research Method 78

Research Methodology and Design 82
Population and Sample 83
Materials/Instrumentation 85
Operational Definitions of Variables 87
Study Procedures 91
Data Collection and Analysis 92
Assumptions 92
Limitations 93
Delimitations 93
Ethical Assurances 94
Summary 95

Chapter 4: Findings 98

Trustworthiness of the Data 99
Results 99
Research Questions 99
Evaluation of the Findings 104
Summary 106

Chapter 5: Implications, Recommendations, and Conclusions 107

PREVIEW

Implications 111
Recommendations for Practice 114
Recommendations for Future Research 119
Conclusions 121

References 124

Appendices 138
Appendix A: Critical Control Survey 139
Appendix B: Security Maturity Model 140

PREVIEW

List of Tables

Cyber Security Model 45

NCU ZDV Statistics 103

ZDV Attack Comparison 105

Critical Control Measures and Security Maturity Model 111

PREVIEW

Chapter 1: Introduction

The ever-increasing use of Internet-based programs and software applications and programs to enhance both the productivity and on-demand/instant/remote accessibility for business of all shapes and sizes has also inadvertently increased a myriad of security-related cyber vulnerabilities. One key industry that has become a prime target of opportunity for potential cyber-attacks is none other than higher education. Some scholars believe that increasing the security of one sector decreases the security of others (Dunn Cavelty, 2014). Bolstering security of a prime target decreases the likelihood of an attack if there is another prime target with weaker security. The cybersecurity dilemma supposed by this position ranks health services the primary target by incident number; business services as the secondary target by incidents; and the global education sector as the third highest number of security breach incidents in 2015 (Symantec, 2016). While the overall number of breaches was reported to be relatively low at 20, these breaches nevertheless resulted in more than five million identities exposed (Symantec, 2016). The industries that had major breaches the years prior had put more time and effort into the securing of their company's digital information, and by default had made the education industry more vulnerable to attack because of the weaker cybersecurity posture (Soto, 2016).

A relatively new phenomenon in the cybersecurity field known as *zero-day vulnerabilities* (ZDV) is the primary reason for a new research project. The ZDV's are highly dangerous because they remain undetected longer than other forms of cyber-attacks. A ZDV is defined as an attack or threat that exploits a previously unknown vulnerability in a computer application; the exposure is found and attacked instantaneously, with zero time between identifying the weakness and attacking it (Bu, 2014). The core problem with ZDVs is the fact a particular digital attack may go unnoticed for prolonged periods of time and remains a significant

PREVIEW

security/network threat until a remedy is generated, tested, and implemented to secure the cyber realm from ZDVs. Identifying the entities/networks/programs that are actually infected by a ZDV is a point of concern because it may be uncertain how many, and exactly what systems are infected. Furthermore, the actual execution of the haphazard solution or *patch* may aggravate the problem (Symantec, 2016).

Background

Cybersecurity is a field dedicated to protecting the physical components of an information system, and the digital data and framework of an information system. Cybersecurity does not just address the actions of malicious outside actors (i.e. *'hackers'*), but also addresses malicious and non-malicious insiders (i.e. 'employees') (Wall, 2011). Differentiating the types of criminals, and the types of threats focuses the cybersecurity strategy for the defending educational institution.

Cybercrimes are perpetrated in many different ways. A cybercrime is defined as the intent to perpetrate a crime in a virtual setting by manipulating the physical components of an information system or; attacking the digital data and framework of an information system. The typology of cybercrimes is many, but all attacks share the same three elements: (a) tools and techniques to perpetrate the crime, (b) approach or methodology for executing the criminal plan (vector), and (c) the crime itself is the end result of these plans (Singleton, 2013).

The criminal factions responsible for committing cybercrime consists of two subgroups: (a) petty criminals, and (b) professional criminals (Bidgoli, 2006). Applying criminal theory and applying threat intent further dissect the overarching typology of criminality. The main difference between petty and professional is that petty criminals do not rely on their criminal activities, whereas the professional criminal's livelihood and income is a direct reflection of their

PREVIEW

respective activities (Bidgoli, 2006). Petty criminals perpetrating cybercrimes take advantage of opportunities that arise and generally do not join businesses with the intent of committing criminal activity (Bidgoli, 2006). Professional criminals join businesses with the intent to commit criminal activity; preselecting the company they join as a victim (Bidgoli, 2006). The actions of the professional criminal are callous and calculated with the goal of stealing intellectual property, and/or stealing sensitive data (Bidgoli, 2006).

Cyber threat agents are individuals of opportunity and often balance risk versus reward with the ease of stealing data. These threat agents commit malicious activity directed at specific information systems, and/or manipulate the actions of unwitting insiders. Threat agents, also known as *hackers*, sell an individual's personal information thru a larger criminal enterprise with data collected from cyber breaches. The goal of a breach is to gather as much personal information as possible and use the information for nefarious activities such as: obtain property, establish work authorization, financial theft via credit, and to mask criminal activity. To mitigate data breaches, it is important to understand the differences and similarities between an outsider/insider attack, and the malicious/non-malicious intent behind the attack (Wall, 2011), and the criminal typology attack theories (Siegel, 2018).

PREVIEW

There are five categories of criminal theory applied to cybersecurity: (a) cybertheft, (b) cyberdeviance, (c) cybervandalism, (d) cyberwar, and (e) cyberterrorism (Siegel, 2018).

Cybertheft is the use of computer systems and networks for criminal profits; examples are illegal copyright infringement, identity theft, and Internet securities fraud (Siegel, 2018). *Cyerbdeviance* is the sale and distribution of morally tainted material and products over the Internet; examples are Ehooking and, the distribution of pornography and drugs (Siegel, 2018). Ehooking is the use of the Internet to advertise illegal conventions such as sexual services or

drugs and to make contact with the clients (Siegel, 2018). *Cybervandalism* is the use of cyberspace for malicious attacks aimed at disrupting, defacing, and destroying technology; examples are website defacement, worms, viruses, cyberstalking, and cyberbullying (Siegel, 2018). Website defacement occurs when an intruder inserts or substitutes code that misrepresents the website information as 'provocative', or coding to corrupt the site (Siegel, 2018). Worms are programs that attack computer systems and other networks by self-generating and sending themselves to contact lists unbeknownst to the owner (Siegel, 2018).

Cyberstalking is the harassing or threatening behavior leveraged on a person via the Internet, email, or other electronic communication; cyberbullying is the willful and repeated harm towards an individual via electronic communication (Siegel, 2018). *Cyberwar* is the use of the cyberspace for acts of war, including spying and disrupting an enemies' network. The goal is to disrupt the juncture where the virtual electronic reality of cyber systems meets the physical world; examples are logic bombs used to disrupt or destroy secure systems or networks (Siegel, 2018). *Cyberterrorism* is an attack used to disrupt the technological infrastructure of a company or nation (Siegel, 2018).

PREVIEW

Outsider Threats

Outsider attacks on digital information systems are largely committed by criminals and/or criminal organizations. The main category of outside attacks is *hackers.* Hackers are divided into seven sub groups: (a) script kiddies, (b) cyberpunks, (c) password crackers, (d) internals, (e) old guard, (f) cyberterrorists and hacktivists, and (g) pirates (Rogers, 2006). Scholars within the field have currently expanded subgroups for internal (now insider) attacks; and differentiate the fundaments between outsider attacks and insider attacks.

Script kiddies are the hackers that have the least technical skill and include all new hackers (Rogers, 2006). The cyberpunk category includes hackers that have some technical skill and are malicious in their attacks (Rogers, 2006). The password crackers are the hackers that specifically focus their efforts on cracking passwords and decrypting security measures (Loper, 2000; Rogers, 2006). Internals are the disgruntled employee hackers, who abuse their access within a system to attack (Rogers, 2006). Old guard hackers are the hackers that see themselves as the defenders of the Internet, and often hack as a means of reporting potential security breaches to companies (Rogers, 2006). Cyberterrorists and hacktivists are the hackers that are politically, socially, or religiously motivated and carry out attacks in the name of their cause (Parker, 1998; Rogers, 2006). Pirates are the subgroup that includes all users who download or exchange copyrighted software (Loper, 2000; Rogers, 2006).

Non-Malicious Insider Threats

Insider cyber threats to an organization are categorized as either (a) malicious in intent, or (b) well-meaning or negligent with no malicious intent (Wall, 2011). The insider threats pertaining to malicious intent are purported by (a) disgruntled employees, (b) hackers, (c) criminals, (d) spies, and (e) terrorists ((Bidgoli, 2006). The difference in non-malicious attacks between well-meaning and negligent insiders is the premise that negligent insiders' behavior is founded from individual interests, whereas the well-being insider behavior pursues the interests of the organization (Wall, 2011).

Negligent insiders adhere to organizational policies until the policies interfere with self-interests at which point the individual deviates for personal interest (Wall, 2011). An example is step-by-step security protocols that the individual rationalizes as time consuming; justifying the *'cutting of corners'* for optimal time management. Well-meaning insiders align well and adhere

PREVIEW

with organization protocols. The primary goal of meeting mission-oriented objectives often times places the security of digital information as a lower priority (Wall, 2011). An example of this is when an employee is trying to meet a deadline and forwards digital data to themselves to work on at home after hours.

Malicious Insider Threats

A malicious insider threat is perpetrated from within a company by someone who has knowledge of the company's cybersecurity practices. A malicious insider threat is subcategorized into the following: (a) disgruntled employees, (b) hackers, (c) criminals, (d) spies, and (e) terrorists (Bidgoli, 2006).

Disgruntled Employees

The disgruntled employee is the lowest level insider threat. Disgruntled employees are any current or former employee including contractors and consultants whom have access to critical data (Bidgoli, 2006). The disgruntled employee's main motivation is anger and frustration towards the company and uses data to seek revenge against the employer or former employer (Bidgoli, 2006). A disgruntled employee attack causes economic and public perception problems for the employer; in most instances the public is sympathetic towards companies that are attacked from outside entities, but little sympathy to companies that were attacked by insiders (Bidgoli, 2006).

Hackers

Attacks from inside hackers are purported by individuals whom are sympathetic to the hacker mentality (Bidgoli, 2006). The underlying reasons hackers' direct attacks on an employer are that the individuals have a disregard for conventional rules, loose ethical confines, unclear morality, indifference towards personal property, and distinctive curiosity (Bidgoli, 2006). The

PREVIEW

motivation for the attacks is not for monetary, greed, or revenge; the motivating factor is the ego, and/or innate curiosity (Bidgoli, 2006). A major concern of insider hackers is the increased chance of outsider breaches. The hacker culture is one of *'one-upmanship'* meaning that a successful attack is shared with an outside audience, whom may or may not capitalize on the shared knowledge (Bidgoli, 2006).

Criminals

The criminal faction of insider threats has two subgroups: (a) petty criminals, and (b) professional criminals (Bidgoli, 2006). The main difference between petty and professional is that petty criminals do not rely on their criminal activities, whereas the professional criminal's livelihood and income is a direct reflection of their respective activities (Bidgoli, 2006). Petty criminals take advantage of opportunities that arise and generally do not join businesses with the intent of committing criminal activity (Bidgoli, 2006). Professional criminals join businesses with the intent to commit criminal activity; preselecting the company they join as a victim (Bidgoli, 2006). The actions of the professional criminal are callous and calculated with the goal of stealing assets, money, credit card numbers, intellectual property, and personal information (identity theft) to sell on the black market (Bidgoli, 2006).

PREVIEW

Spies

Spies are professional criminals concerned with corporate-sponsored and state-sponsored espionage (Bidgoli, 2006). The use of insiders or *'moles'* is a way for corporations or governments to gain an industry advantage over other competitors. The motivating factors for spies are patriotic, revenge, financial (Bidgoli, 2006), and blackmail. The creation of digital data has generated the use of spies to steal trade secrets and intellectual property; in the past spies were used to steal physical assets and printed intellectual property (Bidgoli, 2006). The most

common threat for a company to deal with is former employees leaving a company with trade secrets or intellectual property and being hired on by a competitor in the industry (Bidgoli, 2006).

Terrorists

Terrorist organizations use every tool available to advance their cause. Once such tool is the use of insiders. The insiders are either spies or employees sympathetic to the terrorist cause (Bidgoli, 2006). The help the insiders give terrorist organizations can be direct, with the use of attacks against physical components, malicious software in the form of viruses; or indirectly with the help of insider information and intelligence (Bidgoli, 2006). Terrorist insider threats are more likely in current times because many American businesses have moved many high-tech jobs to countries with weak government infrastructure having direct ties to terrorist organizations (state-sponsored); and to countries that have terrorist organizations operating within their sovereign domain (non-state sponsored) (Bidgoli, 2006).

Currently, there are only 10 purely cybersecurity firms with market capitalization of over one billion dollars. Symantec is the third largest cybersecurity firm. To understand the scope of the cyber realm and cybersecurity statistics from Symantec, an international cybersecurity firm, helps shed light on the vastness of the issues. Symantec consists of 126.5 million cyber-attack sensors that record thousands of attacks per second (2018). The Symantec framework contains over five petabytes of security threat data, and systems monitor 175 million endpoints spanning 157 countries (2018). Symantec processes roughly 2.4 million emails, filters 338 million emails and 1.8 billion web requests each and every day (2018). Worldwide there is approximately 236 billion emails sent per day. Symantec, the third largest cyber-security firm in the world, filters 338 million emails of the 236 billion emails sent per day. Percentagewise that means Symantec

PREVIEW

filters 0.001% of all emails. Considering emails via spear phishing are one of the dominant vectors used to facilitate a cyber-attack, there is a lot of uncovered, or non-secured areas within the cybersecurity field.

The typology of cybercrimes is many, but all attacks share the same three elements: (a) tools and techniques to perpetrate the crime, (b) approach or methodology for executing the criminal plan (i.e. 'vector'), and (c) the crime itself is the end result of these plans (Singleton, 2013). The criminal factions responsible for committing white-collar cybercrime consists of two subgroups: (a) petty criminals, and (b) professional criminals (Bidgoli, 2006). The main difference between petty and professional is that petty criminals do not rely on their criminal activities, whereas the professional criminal's livelihood and income is a direct reflection of their respective activities (Bidgoli, 2006).

Petty criminals perpetrating white-collar cybercrimes take advantage of opportunities that arise and generally do not join businesses with the intent of committing criminal activity (Bidgoli, 2006). An example of a petty white-collar cybercrime is the theft of personally identifiable information. Professional criminals join businesses with the intent to commit criminal activity; preselecting the company they join as a victim (Bidgoli, 2006). The actions of the professional criminal are callous and calculated with the goal of stealing intellectual property, and/or stealing sensitive data (Bidgoli, 2006). An example of a professional white-collar cybercrime is the theft of sensitive intellectual property from a competing business; such as research and development notes for a new technology.

Tax Fraud

Tax fraud is a relatively targeted white-collar cybercrime that occurs between January and April each year when tax returns are due. One version of tax fraud is the use of personally

PREVIEW

identifiable information (PII) by criminals to generate a fraudulent tax refund. The PII is bought and paid for on the dark web by criminals, whom in turn use credible resources (PII) to initiate a tax refund. Tax refunds are not monitored by credit monitoring services making them hard to identify (Towers Watson, 2017). In the first nine months of 2016 the Internal Revenue Service (IRS) thwarted over $4 billion dollars in tax revenue fraud (Towers Watson, 2017).

In 2014, over 60, 000 peoples' PII was stole from a university medical center. The PII of 953 people was used to file fraudulent tax returns generating $2.2 million dollars in refunds. Refunds of $1.4 million were paid out prior to the fraud being identified by the IRS; the IRS then started an investigation (Towers Watson, 2017). The criminals used proxy servers to mask the location of the filing location; and then transferred the funds to gift cards; using the cards to purchase and ship goods to Venezuela. Only one criminal was arrested (Venezuelan national) and charged with conspiracy to defraud the United States, wire fraud, money laundering, and aggravated identity theft (Towers Watson, 2017).

Interestingly enough, most PII theft is met with free credit monitoring services to the victims, paid for by the management system of the PII. In this case, credit monitoring is nothing more than a consolation prize; having no intrinsic value or guarantee that the crime cannot be repeated using the same stolen information.

Corporate Account Takeover

The Federal Bureau of Investigation (FBI) found that small and medium businesses had over $100 million dollars stolen in November 2011 by *Corporate Account Takeover* (Singleton, 2013). Corporate Account Takeover fraud is committed when criminals surreptitiously obtain a business's financial banking credentials; remotely access one of the business's computers utilizing malicious software; then transfer the money to a criminal enterprise (Singleton, 2013).

PREVIEW

The Tennessee Electric Company Inc. (TEC) was the target of a corporate account takeover scheme in May of 2012. The company had $327, 804 siphoned out of the corporate account they had at TriSummit Bank (Krebs, 2014). The criminals used more than four-dozen money mules to transport the money out of TriSummit Bank surreptitiously. The TEC believes the attack started with an attack on May 8th when they tried to upload payroll documents to the bank's website. Unable to do so, the accountant went into the bank to drop the payroll batch off to be processed. The criminals used a malware intercept to redirect TEC's accountant to a fake website masked as the banks; the accountant then inputted the account information and password. The criminals intercepted the one-time token security key and logged onto the bank website misrepresenting themselves as TEC.

The bank was able to recover $135, 000, leaving TEC with a loss of almost $193, 000. The TEC sued TriSummit bank for the total sum of the cyber heist and is awaiting the verdict. Authorized control measure between TEC and TB were not followed correctly. TriSummit is not financially responsible for money lost by TEC only if TEC did not follow bank guidance. TEC claims that their controller followed bank instructions; pointing out that the bank did not have preauthorization from TEC to release the funds until after the money was siphoned (Krebs, 2014).

PREVIEW

Identity Theft

Identity Theft is the most basic of cybercrime; is the foundation of most cybercrimes; and the gateway for further cybercrimes. The crime is simply the theft of PII. Specific people are the target of identity theft involving specific criminal schemes, whereas the general public's PII is sold to criminal entities via the dark web. In 2017, Equifax, an online credit monitoring company was hacked. The criminals stole personal identifying information for approximately 143 million

Americans (Goldman, 2017). The thieves stole social security numbers, birthdates, addresses, an unknown number of driver license numbers, and over 209 thousand credit card numbers.

The breach exploited vulnerability in the Apache web-applications of the websites Equifax used. Apache noticed the vulnerability on March 6th, 2017 and released a patch to fix the problem the next day. Equifax updated their systems and ran scans that did not find additional problems. On March 13th, 2017 criminal cyber agents exploited the vulnerability and gained access to the equivalent of 44% of the population of America's PII (Infotransec, 2017). Equifax did not notice the breach until July 29th, 2017 and immediately fixed the problem. Equifax did not notify the public of the breach until 6 weeks later in September, after three Equifax top executives sold $1.3 million in personal stock.

The data breach is considered the largest in American history and the full effects of the damage are yet to be seen by the American public. After the event Equifax did not notify the public in a timely manner, nor did the try to protect the rights of the consumers. As a result of Equifax's actions, the Federal Trade Commission launched an investigation that is currently ongoing into the breach.

PREVIEW

Theft of Sensitive Data

The Theft of Sensitive Data is an additional layer of identity theft. Sensitive data is the encryption key an organization uses to encrypt PII of personnel and customers, business trade secrets, and source code (Singleton, 2013). In 2015 the Office of Personnel Management (OPM) was breached and criminals stole the security clearance dossiers of over 22 million government personnel (Shedd, 2016). The Chinese government is the main suspect for the data breach. The data breach is of extreme importance because now a foreign entity has potential leverage over people that are entrusted with national security data of the highest sensitivity.

The Inspector General (IG) had published a report highlighting inefficient practices of OPM cybersecurity, and listed solutions prior to the breach. The IG report was ignored, and security solutions were not implemented. The OPM has paid out more than $133 million dollars to identity theft and credit monitoring services for three years of coverage. However, the three-year limit is public knowledge, meaning cyber criminals need to hold the data for three years before using it for nefarious purposes.

The OPM have no long-term plan to address the breach, nor have they publicly addressed the espionage purported by another nation (Shedd, 2016). This is extremely concerning, as another nation has a list of PII pertaining to government employees with the highest of security clearance; essentially it is a target list of candidates for blackmail.

Theft of Intellectual Property

The Theft of Intellectual Property concerns mostly business entities with commercially copyrighted material. Criminals access the intellectual property by committing commercial espionage. Between 2012 and 2014 a cyber hacking ring was responsible for intellectual property theft of between $100 and $200 million dollars (Walker, 2015). A team of three hackers pleaded guilty to conspiracy to commit cyber intrusions and criminal copyright infringement. The thieves targeted the Microsoft gaming console Xbox One, and the linked Microsoft live accounts (Walker, 2015). The criminals accessed the Microsoft Corporation, Epic Games Inc., Valve Corporation, and Zombie Studios; stealing unreleased software, software source code, trade secrets, copyrighted material, and other sensitive intellectual data.

The hackers' method of theft involved stealing clients log-ins and using Structured Query Language (SQL) injection. A SQL injection is perpetrated by exploiting a security vulnerability occurring in the database layer of an application. The SQL code is injected into an applications

PREVIEW

query field resulting in criminal access to the underlying data, structure, and the database management system. The criminals received 18 months prison time for the theft. Microsoft 'patched' the security vulnerability; however, the ensuing damage from the breach could not be stopped. The criminals ranged in age from 18 to 22 and were computer science students at a premiere university.

There are multiple obstacles that are used to secure a website from SQL injection attacks. Comprehensive data sanitization is the process of filtering only required characters in specific data fields; a web application firewall filters dangerous web requests; avoiding SQL queries on a website limits the avenue of attack; and, limiting database privileges by context reduces the leverage an attack has on compromising the whole database (Weiss, 2016).

Security

There are two forms of protection relative to cybersecurity: (a) cybersecurity, and (b) physical security. Cybersecurity constantly evolves to proactively address threats. Current solutions to address the loss of digital data are: (a) updated password guidance, (b) layered identity proofing, (c) layered authentication process, (d) layered federation security protocols, and (e) physical authorization and access control. Physical security encompasses the checkpoints to gain access to the actual hardware of a network, the buildings or rooms of the hardware, and the hardware itself. Balancing American civil liberty protections with tools used for intelligence gathering purposes generates controversy for protecting America from foreign and domestic threats. The Bill of Rights and the United States' Constitution specifically protect the citizenry from government infringement. As technology has evolved the fundaments of protecting civil liberties has constantly been redefined.

PREVIEW

The approach to securing digital data has shifted in recent years by layering security protocols and enhancing security barriers. A notable shift in security protocols is the user-friendly password criteria and shifting more of the 'proofing' burden to the verifier (Wisniewski, 2016). The new guidance increases the password length to a maximum of 64 characters, including all ASCII and Unicode characters. The guidance resists the use of knowledge-based authentication, password hints, and password expiration (Wisniewski, 2016).

The National Institute of Science and Technology (NIST) released the NIST Special Publication 800-63-3 (2017) to address shortfalls with digital identity guidelines. Any digital or online transaction uses a digital identity. These digital identities are nothing more than digital personas and may not be the actual identity of a person (NIST, 2017). One of the fundamental goals of cybersecurity is to provide authenticity of a digital identity at any/all layers of security. Matching an online persona, with an online digital identity still offers an individual anonymity it instances where a third-party service is 'vouching' for the identity: essentially the middleman of the transaction (NIST, 2017). There are three components identity assurance: (a) identity assurance level (IAL), (b) authenticator assurance level (AAL), and (c) federation assurance level (FAL) (NIST, 2017).

PREVIEW

Identity proofing is the act of verifying one's online persona by linking key information via a 'subscription' process (NIST, 2017). As an example, when a person opens a new email account with a service, certain questions are asked and answered. The answers to these questions are then linked to the account by which the person is designated a subscriber. Identity proofing has three different levels of security. A risk analysis is done by the cyber entity to assess potential damage from a false identity; then implements the appropriate security measure corresponding to the IAL levels of protection (NIST, 2017). IAL level 1 is the lowest level of

proofing and does not require linking an online identity with a real-life identity; IAL2 links a real-world identity with an online identity either remotely or the person being physically present to produce supporting elements; IAL3 requires the physical presence of an individual whom is then verified by personnel authorized and trained by a Credential Service Provider (CSP) (NIST, 2017). It is important to note that the initial identity proofing level does not link a real identity to an account, but rather can be established anonymously.

Authentication and Lifecycle Management (AAL) addresses risk-based assurances that an entity accessing a service is the same entity that previously accessed the service (NIST, 2017). The AAL has three different levels of security that are implemented based on the risk analysis of an entity gaining access to a system or services data via authentication controls (NIST, 2017). The initial layer of security (AAL1) provides some assertion that the applicant governs an authenticator assured to the subscriber's account; AAL2 provides high confidence in the verification that the authenticator is bound to the subscriber's account via two distinct verification factors using mandatory cryptography; AAL3 provides very high confidence in the verification that the authenticator guarantees the subscriber's account via two distinct verification factors using a mandatory cryptology key and a hardware-based authenticator providing verification impersonation resistance (NIST, 2017). The three cornerstones of AAL are: (a) something you know, (b) something you have, and (c) something you are (NIST, 2017). Something you know is basically a password. Something you have is a badge, cryptographic key, or common access card. Something you are refers to biometrics, such as retinal scan, fingerprint etc.

Use of a governmental system incorporates authentication by a federated identity provider (IdP) or a relying party (RP) (NIST, 2017). The Federation Assurance Level (FAL) has

PREVIEW

three distinct levels. FAL1 allows a subscriber to push a bearer assertion to a RP, the assertion is then signed using cryptography by the IdP; FAL2 includes the additional requirement of the IdP signature be encrypted by which the RP is the only entity able to decrypt; and FAL3 requires proof from the RP that it in fact has the decryption key referenced in the assertion (NIST, 2017). The use of a relying party in a federated system adds a layer of identity proofing that generates access of the subscriber to other RP's without having to individually subscribe to each agency (NIST, 2017).

Physical security is an often-overlooked aspect of securing cyber information systems. Poor physical security equates to unauthorized persons having access to the physical components of an information system. Access to information system components (ISC) is one way that bad actors manipulate systems and data. As an example, instead of attacking a well-protected information system (cybersecurity) with cyber tools that may or may not work, one could walk into a less secure facility where the physical components are and walk out with them. There are many components to safeguarding digital data. One component is that of Physical and Environmental Protection Control (PEPC) (NIST, n.d.). The PEPC component is broken down into twenty subcomponents (NIST, n.d.). Two subcomponents of dire consequence to proper physical security are: (a) physical access authorization, and (b) physical access control. Physical access authorization is a proactive measure to screen and control employee authorization to access physical components. Physical access control is a proactive security measure used to compartmentalize or limit a person's access to system infrastructure.

Key components to successful access control are access authorizations and physical access control (NIST, n.d.). The premise is to incorporate appropriate proactive measures to limit access to the physical components of a digital network. The concern of a data breach and the

PREVIEW

Reproduced with permission of copyright owner. Further reproduction prohibited without permission.